Seguridad en Redes y Análisis Inteligente de Amenazas

Tema 10. Seguridad en Cloud

Índice

Esquema

Ideas clave

10.1. Introducción y objetivos

10.2. Redes Virtuales

10.3. Identity and Access Management

10.4. Seguridad en la nube como servicio (Secaas)

10.5. Referencias bibliográficas

A fondo

The Journey to Cloud Networking

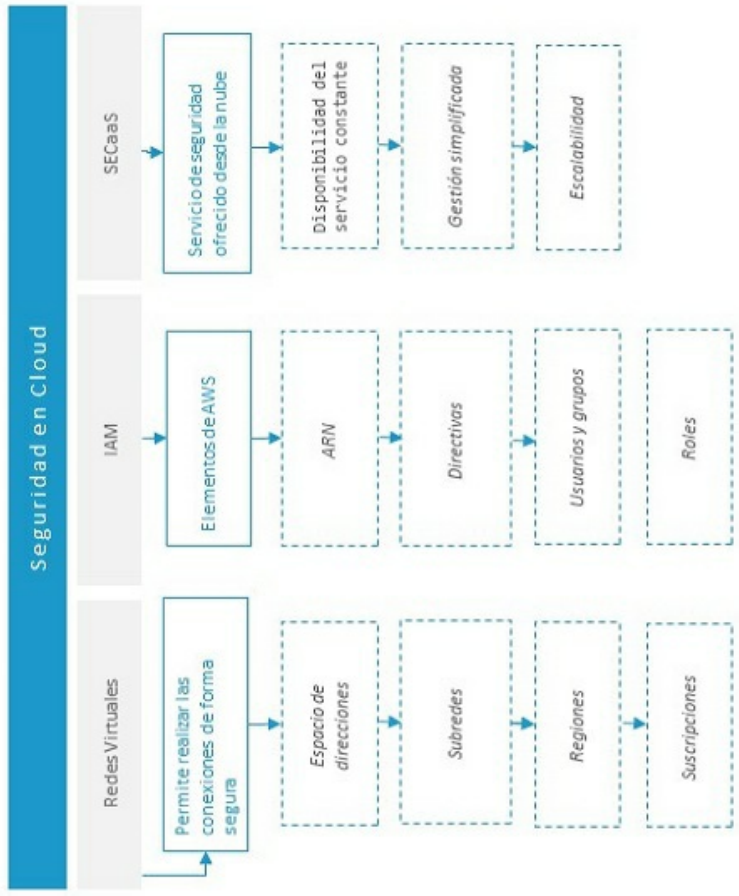
Despliegue de Cisco en AWS

Arquitectura con múltiples redes virtuales en AWS

Introducción a IAM

Test

Esquema



© Universidad Internacional de La Rioja (UNIR)

10.1. Introducción y objetivos

En este tema se van a ver los elementos esenciales para desplegar nuestros servicios en un **entorno en la nube** de forma segura. Por un lado, se verá el concepto de **redes virtuales** y cómo estas nos permiten conectar esos recursos en la nube con otros que podemos tener desplegados en local. Por otro lado, se va a ver el concepto de **IAM** en entornos en la nube, y cómo se especifican los **permisos** que tienen los usuarios sobre los recursos de una forma granular a través del **caso de AWS.**

Finalmente, se va a analizar una **nueva tendencia** en la que los **servicios de seguridad** ya no se despliegan de forma local, sino que son ofrecidos **en la nube.**

© Universidad Internacional de La Rioja (UNIR)

10.2. Redes Virtuales

Las **redes virtuales en la nube** permiten que muchos tipos de recursos, como las máquinas virtuales, se comuniquen de manera segura entre sí, con Internet y con las redes locales *on-premise*. Son similares a la red tradicional de un centro de datos, pero tienen **beneficios adicionales** de la infraestructura nativa de nube, como la escalabilidad y alta disponibilidad.

Los servicios de red virtuales son la base para construir **soluciones de nube nativas e híbridas,** permitiendo conectar, de forma segura, los recursos nativos y la infraestructura de nube a los centros de datos físicos.

Los **elementos principales** son:

- **Espacio de direcciones:** al crear una red virtual, es necesario especificar un espacio de direcciones IP privadas.
- **Subredes:** las subredes permiten segmentar la red virtual en una o más redes, y asignar una parte del espacio de direcciones de la red virtual a cada subred. Los recursos podrán desplegarse en la subred necesaria, de acuerdo con las necesidades de la arquitectura de los sistemas. Al igual que en una red tradicional, la segmentación de las subredes mejora la eficiencia de asignación de direcciones. Además, los recursos dentro de las subredes se pueden proteger utilizando grupos de seguridad de red.
- **Regiones:** una región es un conjunto de centros de datos, implementados dentro de un perímetro con una latencia definida y conectados a través de una red regional dedicada de baja latencia. Aunque las redes virtuales tienen un alcance para una sola región, se pueden conectar varias redes virtuales de diferentes regiones mediante el emparejamiento de redes virtuales.
- **Suscripción:** las redes virtuales están asociadas a una cuenta, pero en una cuenta

© Universidad Internacional de La Rioja (UNIR)

se pueden definir tantas redes virtuales como se necesite.

Una vez tenemos nuestra red virtual, se nos presentan **diferentes escenarios de interconexión:**

- **Conexión con Internet:** de manera predeterminada, todos los recursos en una red virtual pueden iniciar comunicación saliente hacia Internet. En sentido contrario, sin embargo, los recursos son accesibles desde Internet si se les asigna una dirección IP pública, o un balanceador de carga, y el tráfico está permitido con un grupo de seguridad de red.

- **Conexión con otros recursos en la nube:** se conectan entre sí a través de la red virtual o, si estuviesen situados en diferentes redes virtuales, mediante el emparejamiento de estas.

- **Conexión con recursos locales:** los recursos locales y las redes virtuales en la nube se pueden conectar a través de una VPN.

En el vídeo, *Definición de una red virtual en Azure,* se muestra un ejemplo para la creación de una red virtual en Azure.

© Universidad Internacional de La Rioja (UNIR)

10.3. Identity and Access Management

IAM permite administrar quién puede acceder a los recursos y qué acciones puede ejecutar. Tener una política de IAM bien planificada es una parte importante de la seguridad. IAM distingue entre autenticación, que está basada en usuarios y grupos; y autorización, que se basa en políticas.

Los proveedores en la nube integran en sus plataformas IAM para controlar el acceso a los diferentes recursos. A continuación, vamos a ver la forma en la que IAM es gestionado dentro de AWS.

IAM en AWS

En esta sección vamos a analizar cada uno de **los componentes utilizados para el despliegue de una solución IAM en AWS.**

ARN

Para identificar los recursos, entre ellos a los usuarios de IAM, AWS usa ***los Amazon Resource Names.*** Un ARN es un identificador único global que hace referencia a objetos de AWS. La mayoría de los tipos de recursos de AWS tienen ARN, incluidos los objetos de S3 y los roles, usuarios y directivas de IAM. Tienen el siguiente formato:

arn:partition:service:region:account-id:resource-type/resource-id

donde:

- partition: una partición es un grupo de regiones de AWS: aws, aws-cn (regiones de China), aws-us-gov (regiones GovCloud de EE. UU.). Una cuenta en AWS pertenece a una única partición.
- service: identifica el tipo de servicio de AWS que ofrece el recurso: s3, iam, ece2,

© Universidad Internacional de La Rioja (UNIR)

etc.

- region: identifica la región en la que está ubicado el recurso. Este campo no es necesario si se trata de un recurso definido de manera global.
- account-id: el ID de la cuenta propietaria del recurso. Es omitido para algunos recursos globales.
- resource-id: el identificador del recurso, que puede ser un identificador o una ruta.

Directivas de IAM

La idea detrás de IAM es separar a los usuarios y grupos de las acciones que necesitan realizar. Para ello, se crean **directivas de IAM,** que son documentos JSON que describen qué acciones puede realizar un usuario. Esta política se aplica a los usuarios o grupos, dándoles acceso solo a los servicios que especifica el documento.

U n **permiso** es una combinación de dos elementos: una acción y una lista de recursos. AWS verificará si el usuario autenticado puede realizar la acción solicitada en un recurso específico. Las acciones se definen como cadenas de texto con el formato servicio:permiso.

Los **elementos** que utilizamos para definir una **directiva** son:

- **Los statements o declaraciones:** la declaración es la pieza elemental de una directiva, ya que enlaza acciones y recursos. El campo statement es realmente una **lista de subdocumentos,** por lo que una única directiva puede tener varias declaraciones.
- El campo effect indica si se **habilitan las acciones** sobre los recursos, con Allow, o si se deniegan explícitamente, con Deny. Por defecto, un usuario al que no se le aplica ninguna directiva no tendrá permiso para ejecutar ninguna acción sobre ningún recurso. El valor Deny en effect sirve, por tanto, para denegar permisos

© Universidad Internacional de La Rioja (UNIR)

específicos que pueden haber sido habilitados por otra directiva.

- El campo action especifica las **acciones permitidas o denegadas** sobre los recursos. Puede ser un campo de texto, en cuyo caso, especifica una única acción, o una lista. Las acciones admiten comodines en el permiso para reducir el número de permisos que hay que escribir para conseguir un determinado acceso. Por ejemplo, una directiva puede dar acceso completo al servicio EC2 con la acción ec2:*, que, de no usar un comodín, habría que escribir los más de cuatrocientos permisos disponibles.

- El campo resource especifica el recurso o recursos, identificados con ARN, sobre los que hace efecto la declaración. Al igual que action, puede ser un campo de texto o una lista.

A continuación, se muestra un ejemplo de directiva.

```
{
"Version": "2012-10-17",
"Statement": [{
"Sid": "VisualEditor0",
"Effect": "Allow",
"Action": [
"ec2:RebootInstances",
"ec2:DescribeInstances"
],
"Resource": "*"
}]
```


© Universidad Internacional de La Rioja (UNIR)

}

Usuarios y grupos

Un usuario puede ser un humano que inicia sesión en la consola de administración web, con un nombre de usuario y contraseña, o un programa que utiliza un conjunto de credenciales de acceso para interactuar con las API de AWS. Al usuario se le pueden asignar una o más directivas de IAM, que especificarán las acciones que puede realizar.

Al crear un usuario, hay que especificar si podrá iniciar sesión en la consola, o si podrá acceder a las API directamente con un SDK, o la herramienta de línea de comandos.

El acceso a las API se realiza con una clave y un secreto adicionales, aleatorios y más complejos que un nombre de usuario y una contraseña normales. Cada usuario puede tener dos claves activas. El objetivo de estas claves es usarlas en cuentas de servicio, tareas automáticas, etc.

Dado que estas cuentas no pueden cambiar la contraseña por sí mismas, es necesario disponer de, al menos, dos claves para poder rotarlas. La rotación de claves era un proceso complicado que se vio aligerado con la aparición de los roles en 2012.

Roles

Al igual que los usuarios y grupos, los roles de IAM pueden tener una o más directivas aplicadas. Estos roles se aplican, entonces, a una instancia en el momento del arranque. AWS generará automáticamente la clave y el secreto de acceso, y los pondrá a disposición de la instancia a través de la API de metadatos.

Estas credenciales se pueden usar para acceder a los servicios de AWS con los

© Universidad Internacional de La Rioja (UNIR)

permisos especificados por las políticas del rol. Los SDK de AWS y awscli están preparados para leer estas claves automáticamente, sin necesidad de que los desarrolladores ni los administradores se tengan que encargar de indicar configuración alguna. El único requisito es que la aplicación debe ejecutarse en una instancia de EC2. Además, AWS rotará regularmente las claves durante la vida útil de la instancia, sin requerir ninguna acción por parte de los administradores.

Los roles se pueden aplicar también a otros servicios de AWS como Lambda o API Gateway, usuarios (dentro y fuera de una organización), aplicaciones móviles o a terceras entidades, para permitir que un proveedor administre ciertos recursos en la cuenta del cliente.

El uso de roles para dar permisos en otras cuentas ofrece más flexibilidad para administrar recursos, presupuestos y credenciales. Es habitual que las organizaciones dispongan de múltiples cuentas de AWS para identificar, claramente, los límites de gasto. En estas situaciones no es viable mantener usuarios y sus credenciales en todas las cuentas.

Para ello, se pueden asignar roles de una cuenta (A) a usuarios de otra cuenta (B). Cuando un usuario de la cuenta B quiere operar sobre recursos de la cuenta A, el usuario asume un rol de la cuenta B. Las acciones que puede llevar a cabo están delimitadas por las directivas aplicadas a ese rol, no a las aplicadas al usuario. Esto es especialmente relevante cuando las dos cuentas implicadas pertenecen a organizaciones diferentes. Puede servir, por ejemplo, para dar control sobre una cuenta a una herramienta de gestión de ciclo de vida de aplicaciones o de copias de seguridad ofrecida como servicio. Estas herramientas se integran con la API de AWS y usan sus propias credenciales para iniciar sesión, relevando al cliente de la rotación de claves o la gestión de usuarios bloqueados o caducados.

En el vídeo, *IAM en AWS,* se muestra la gestión de los permisos de un recurso desplegado en AWS.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

© Universidad Internacional de La Rioja (UNIR)

10.4. Seguridad en la nube como servicio (Secaas)

Secaas se refiere a ofrecer servicios de seguridad, que tradicionalmente están desplegados dentro de las redes de las empresas, en un entorno en la nube. Cada vez existe un listado más amplio de **servicios de seguridad** que se ofrecen en entornos en la nube, entre los que se encuentran:

- Gestión de Identidades y Accesos.
- *Data Loss Prevention*.
- Seguridad Web tales como filtrado web, análisis de vulnerabilidades, monitorización, etc.
- Seguridad del correo electrónico.
- SIEM.
- VPN.
- Herramientas de seguridad perimetral como *firewalls*, IDS, etc.

Sin duda, el delegar los servicios de seguridad en entornos en la nube nos ofrece una serie de **ventajas:**

- Disponibilidad del servicio constante.
- Gestión simplificada.
- Escalabilidad.

Sin embargo, siempre debemos tener en cuenta que la seguridad de nuestra organización queda delegada a un tercero y debemos acotar muy bien los acuerdos del servicio.

© Universidad Internacional de La Rioja (UNIR)

10.5. Referencias bibliográficas

Amazon Web Services. (S. f.). *Client VPN endpoints.* https://docs.aws.amazon.com/vpn/latest/clientvpn-admin/cvpn-working-endpoints.html

Chandrasekaran, K. (2014). *Essentials of cloud computing.* CrC Press.

Ko, R., & Choo, R. (2015). *The cloud security ecosystem: technical, legal, business and management issues.* Syngress.

Lucifredi, F y Ryan, M. (2018). *AWS System Administration.* O'Reilly Media.

Tullock, M. (2013). *Introducing Windows Azure for IT Professionals.* Microsoft Press.

© Universidad Internacional de La Rioja (UNIR)

The Journey to Cloud Networking

Sciarrilli, N. (2020, abril 28). *The Journey to Cloud Networking.* https://aws.amazon.com/es/blogs/architecture/the-journey-to-cloud-networking/

Artículo que repasa algunas ideas que sirven para reflexionar sobre cómo afrontar un despliegue o una migración de redes a la nube, que, aunque es específico de AWS, las ideas que plantea se aplican a cualquier proveedor.

© Universidad Internacional de La Rioja (UNIR)

Despliegue de Cisco en AWS

Cisco Systems. (2019, junio 16). Deploying Cisco Web Security and Security Management Virtual Appliances on Amazon. Elastic Compute Cloud on Amazon Web Services.
https://www.cisco.com/c/dam/en/us/td/docs/security/content_security/virtual_appliances/Cisco_Content_Security_Virtual_Appliance_Install_Guide_AWS_EC2.pdf

Ejemplo de despliegue de dos *appliance* de Cisco en AWS.

© Universidad Internacional de La Rioja (UNIR)

Arquitectura con múltiples redes virtuales en AWS

Amazon Web Services. (2020). *Building a Scalable and Secure Multi-VPC AWS Network Infrastructure.* https://d1.awsstatic.com/whitepapers/building-a-scalable-and-secure-multi-vpc-aws-network-infrastructure.pdf?did=wp_card&trk=wp_card

Esta guía presenta una arquitectura de red compleja para AWS. No es una guía paso a paso, sino una guía de referencia, en la que se explica brevemente los recursos que se van a usar, qué papel juegan en esta arquitectura y cómo se integran entre ellos.

© Universidad Internacional de La Rioja (UNIR)

Introducción a IAM

Simplilearn. (2016, junio 30). AWS IAM Tutorial | *AWS Identity And Access Management | AWS Tutorial | AWS Training | Simplilearn* [Vídeo]. YouTube. https://www.youtube.com/watch?v=3A5hRIT8zdo

Este vídeo resume las principales características de IAM y algunas mejores prácticas para crear recursos. Es muy recomendable como recurso complementario al material de este tema.

© Universidad Internacional de La Rioja (UNIR)

Test

1. ¿Con qué formato se indican los recursos a los que aplica una directiva de IAM?

A. JSON.

B. ARN.

C. La opción A y B son posibles.

D. Ninguna de las anteriores.

2. ¿Qué permisos por defecto recibe un usuario al que no se le aplica ninguna directiva de IAM?

A. Ninguno.

B. De impersonación.

C. Solo de lectura sobre todos los recursos de la cuenta.

D. Todos los permisos están habilitados, a menos que los restrinja una política explícitamente.

3. ¿Qué valor debe tener el campo effect para permitir una acción?

A. Allow.

B. Deny.

C. Read.

D. Enabled.

4. ¿Qué elemento me permite reducir el número de permisos que debo especificar para acceder a un recurso?

A. ARN.

B. Roles.

C. Comodines.

D. Ninguna de las anteriores.

© Universidad Internacional de La Rioja (UNIR)

5. ¿Cuál de los siguientes elementos es parte de las redes virtuales?

A. Espacio de direcciones.

B. Subredes.

C. Regiones.

D. Todas las opciones son correctas.

6. ¿Con qué formato se indican las directivas de IAM?

A. JSON.

B. ARN.

C. La opción A y B son posibles.

D. Ninguna de las anteriores.

7. ¿Qué es Secaas?

A. Ofrecer un servicio de seguridad desde un entorno en la nube.

B. Prohibición de desplegar servicios en entornos en la nube.

C. Ofrecer servicios de seguridad de forma local, estando prohibida su interconexión con Internet.

D. Ninguna de las anteriores.

8. ¿Cuál de las siguientes características nos ofrecen los servicios de seguridad dados desde la nube?

A. Gestión simplificada.

B. Escalabilidad.

C. Disponibilidad del servicio constante.

D. Todas las opciones son correctas.

© Universidad Internacional de La Rioja (UNIR)

9. Los roles en AWS:

A. Se pueden aplicar únicamente a usuarios de dentro de la organización.

B. Se pueden aplicar únicamente a usuarios de fuera de la organización.

C. Se pueden aplicar a usuarios de dentro y de fuera de la organización.

D. No se pueden definir roles en AWS.

10. ¿Cómo se gestiona en AWS el acceso a las API?

A. Únicamente con usuario y contraseña.

B. Con una clave y un secreto adicionales.

C. Únicamente con certificados digitales.

D. Ninguna de las opciones anteriores es correcta.

© Universidad Internacional de La Rioja (UNIR)